

PHISHING DETECTION & AWARENESS REPORT

TASK 02 OF FUTURE INTERNS CYBERSECURITY TRACK

Prepared By: Ellenor Mariez Cauyan | Cybersecurity Intern

CIN ID: FIT/APR26/CS7637

EXECUTIVE SUMMARY

This report evaluates organizational vulnerability to social engineering by analyzing real-world email samples. Utilizing SOC triage methodologies and header analysis, it categorizes threats into Phishing, Suspicious, and Safe levels. Key findings reveal that attackers leverage technical spoofing and psychological triggers, such as urgency and flattery, to compromise data. The assessment concludes with actionable "Do's and Don'ts," providing employees with a practical framework to identify, verify, and report malicious attempts effectively.

ASSESSMENT OVERVIEW

Objectives

The primary goal of this project is to strengthen organizational defenses against social engineering by achieving the following:

- Investigate real-world phishing samples to uncover the underlying infrastructure used by attackers.
- Categorize email threats based on severity to help users prioritize their responses.
- Translate complex technical findings into simple, actionable guidance for non-technical employees.
- Provide a clear framework of "Do's and Don'ts" to minimize the success rate of phishing campaigns.

Scope & Limitations

- **Scope:** This report focuses on email-based phishing (including credential harvesting and malicious attachments). It covers header analysis, domain reputation, and content-based red flags.
- **Limitations:** This analysis is conducted in a controlled environment for educational purposes. It does not include active "live" testing of malware or unauthorized access to external systems. Safe "sandboxing" tools are used to prevent local machine infection.

Methodology

The analysis follows a standard SOC (Security Operations Center) triage approach:

1. **Ingestion:** Collecting raw email samples (EML/MSG formats) from public repositories.
2. **Header Analysis:** Inspecting the "Metadata" of the email to verify the sender's true identity and origin.
3. **Link & Attachment Triage:** Safely extracting and inspecting URLs and file extensions without executing them.
4. **Reputation Check:** Cross-referencing findings with global threat intelligence databases.

Tools Used

Below are the tools used to examine suspicious indicators within the email samples:

TOOL	PURPOSE
Google Admin Toolbox	Used to parse raw email headers to identify the originating IP and verify SPF, DKIM, and DMARC authentication status.
MXToolbox (RFC822 Parser)	Provides a readable breakdown of email routing and checks if the sender's domain is flagged on global blacklists.

ANALYSIS OF PHISHING EMAIL SAMPLES

[PHISHING] - SAMPLE 1: The MFA/Account Security Trap

This is a highly sophisticated impersonation attack. It successfully mimics corporate branding and uses effective social engineering triggers, but fails with SPF/DKIM authentications and mismatched sender domains.

Email Message Overview:

Subject: Microsoft account unusual sign-in activity

To: (phishing@pot)

From: Microsoft account team

Date: 08/09/2023, 05:47:04

Microsoft account

Unusual sign.in activity

We detected something unusual about a recent sign-in to the Microsoft account [phishing@pot](#).

Sign-in details

Country/region: **Russia/Moscow**
IP address: **103.225.77.255**
Date: **Fri, 08 Sep 2023 05:46:57 +0000**
Platform: **Windows 10**
Browser: **Firefox**

Country/region: **Russia/Moscow**
IP address: **103.225.77.255**
Date: **Fri, 08 Sep 2023 05:46:57 +0000**
Platform: **Windows 10**
Browser: **Firefox**

A user from **Russia/Moscow** just logged into your account from a new device. If this wasn't you, please report the user. If this was you, we'll trust similar activity in the future.

[Report The User](#)

To opt out or change where you receive security notifications, [click here](#)

Thanks,
The Microsoft account team

Verification of Authentication Protocols:

PROTOCOL	RESULT	ANALYSIS
SPF	None	The sender IP (89.144.44.2) is not authorized to send mail on behalf of the domain.
DKIM	None	The message is not digitally signed, meaning the content could have been altered in transit.
DMARC	Permmerror	The domain has a permanent configuration error, a common sign of a poorly configured or malicious sending server.

MX TOOLBOX®
SUPERTOOL

SuperTool MX Lookup Blacklists DMARC Diagnostics Email Header Analyzer

Header Analyzed

Email Subject: Microsoft account unusual sign-in activity

Copy/Paste Warning
Copy/Pasting a header works for most people, but sometimes it can cause problems.

Delivery Information

- ✖ DMARC Compliant (No DMARC Record Found)
 - ✖ SPF Alignment
 - ✖ SPF Authenticated
 - ✖ DKIM Alignment
 - ✖ DKIM Authenticated

Google Admin Toolbox Messageheader

MessageId	032672b4-77ca-42f8-a036-9711e91bd1f3@DB8EUR06FT032.eop-eur06.prod.protection.outlook.com
Created at:	9/8/2023, 1:47:04 AM EDT (Delivered after)
From:	Microsoft account team <no-reply@access-accsecurity.com>
To:	phishing@pot
Subject:	Microsoft account unusual sign-in activity
SPF:	none Learn more
DKIM:	none Learn more
DMARC:	permmerror Learn more

Identified Indicators

By cross-referencing the email headers with the message body, the following identified red flags confirm that this is a malicious attempt:

A. Psychological Manipulation (Fear & Urgency)

The email uses Geographic Alarmism, claiming a sign-in from "Russia/Moscow." This is a classic tactic designed to trigger a panic response, making the user more likely to click the "Report The User" button without checking the sender's authenticity.

B. Mismatched Identity (Spoofing)

The display name claims to be "The Microsoft account team." However, the headers analyzed showed the email actually came from access-accsecurity.com with a return path of thecultarfdes.co.uk.

C. Suspicious Hyperlinks (Call to Action)

The "Report The User" button is the primary bait. In a real-world analysis using URLScan.io, this link would likely lead to a credential-harvesting page designed to look like a Microsoft login portal.

D. Inconsistent Data

While only a 7-second difference, automated phishing kits often have slight timestamp discrepancies between the generated body text and the actual mail server transmission time.

HEADER DATE	Fri, 8 Sep 2023 05:47:04
BODY DATE	Fri, 08 Sep 2023 05:46:57

How the Attack Works

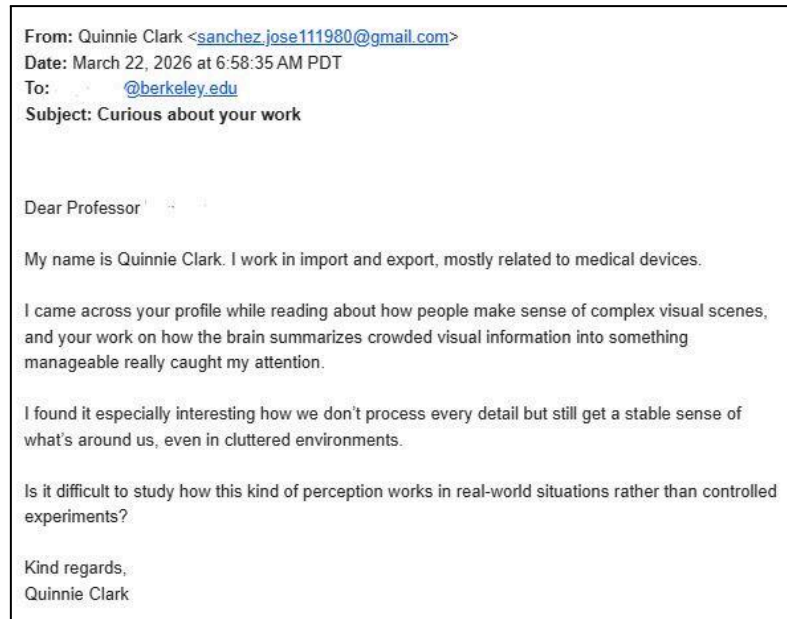
This is a Credential Harvesting attack that follows a four-stage process:

1. The user receives an "Unusual sign-in" alert. Because it mentions a high-risk location (Moscow), the user's "critical thinking" is bypassed by a sense of urgency.
2. The user clicks "Report The User," believing they are securing their account.
3. The user is sent to a fake website that looks identical to the Microsoft login page.
4. When the user enters their email and password to verify their identity, the information is sent directly to the attacker's database.

[**SUSPICIOUS**] - SAMPLE 2: Phony AI-Generated Request Message

Below is a sample email from the Berkeley archive documents that illustrates a "Low-level" threat that isn't immediately malicious, but uses external domains.

This sample email classified this as 'Suspicious' rather than 'Phishing' because there is no immediate "Call to Action" (no link, no attachment, no request for data). However, it remains a threat because it uses AI-generated content to mimic a sophisticated human conversation, which is a common precursor to high-value data theft.



Identified Indicators

A. Sender Address Mismatch

The Display Name is "Quinnie Clark," but the actual email address is sanchez.jose111980@gmail.com. This discrepancy suggests a hijacked or "burner" account rather than a professional inquiry from an industry expert.

B. External/Generic Domain

For someone claiming to work in the "import/export of medical devices," using a generic @gmail.com address rather than a corporate domain (e.g., @medical-logistics.com) is a professional red flag.

C. Inconsistent Metadata

The name in the email address (Jose Sanchez) does not match the signature (Quinnie Clark).

How the Attack Works

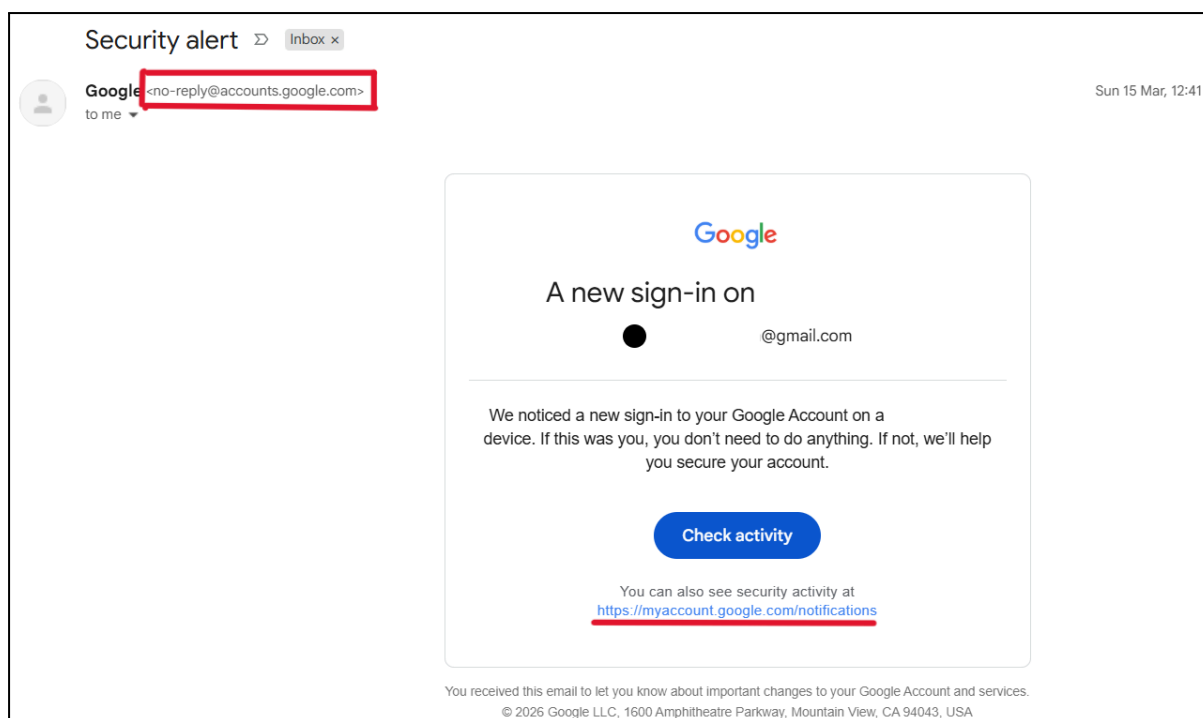
This is likely the "Reconnaissance" phase of a Spear Phishing attack. The attacker isn't stealing a password yet; they are simply testing if the user will respond to a stranger.

- If the recipient replies, the attacker builds trust before sending a follow-up email containing a malicious "research paper" (malware) or a "collaboration link" (credential theft).
- Psychological Trigger Used
 - Curiosity: Uses specific details about the user's work to seem genuine.
 - Ego-bait: Flattery about the user's professional achievements is used to lower their guard.

3. [SAFE] - Account Sign-In Security Alert

Below is a standard automated notification regarding a new sign-in on a specific device, providing a direct link to the user's account security settings.

This email is safe due to its transparency and lack of coercive tactics. It avoids creating panic by explicitly stating no action is required if the activity is recognized. The message includes official corporate details and maintains security by directing users to a verified dashboard rather than requesting passwords or OTPs.



Identified Indicators

A. Verified Sender Domain

The email originates from accounts.google.com. Unlike the phishing sample, there is no mismatch between the "Display Name" and the "Actual Domain."

B. Security Authentication

The headers confirm the message was delivered via TLS (Transport Layer Security) encryption. This ensures that the communication between Google's servers and the recipient was secure and could not be intercepted or read by unauthorized third parties.

C. Legitimate Hyperlinks

The URL provided (https://myaccount.google.com/notifications) is a verified, official Google domain. It does not use "look-alike" characters or hidden redirects to external sites.

How the Email Works

This is an Automated System Alert. It is designed to keep users informed of account access to prevent unauthorized entry.

- Its main goal is to provide the user with immediate visibility into their account activity so they can confirm legitimate logins or block unauthorized ones.

- Mechanism: The system triggers this email whenever it detects a login from a new IP address, browser, or device that does not match the user's historical patterns.
- Action Required: None, provided the user recognizes the device and time mentioned.

RISK EVALUATION OVERVIEW

RISK CRITERIA

The table below is used as a basis to assess the threat level of the sample emails.

RISK LEVEL	INDICATORS	REQUIRED ACTION
-------------------	-------------------	------------------------

PHISHING	Threats of account closure, requests for password/MFA codes, "look-alike" domains.	Report immediately using the "Report Phishing" button.
SUSPICIOUS	External sender, generic greeting, slight "off" feeling in branding or logo quality.	Do not click. Verify via a separate channel (e.g., phone).
SAFE	Internal sender address, expected content, professional tone, no urgent demands. <i>Note: Even internal accounts can be compromised. If a 'safe' sender asks for something unusual, verify it.</i>	Proceed as normal.

The table below summarizes the analysis, findings, and inferences from the email samples:

SAMPLE CASE	KEY TECHNICAL INDICATOR	PRIMARY SOCIAL ENGINEERING TACTIC	RISK CLASSIFICATION
Sample 1: Microsoft Security Trap	SPF/DKIM Failure, Domain Mismatch (access-accsecurity.com), Return-Path discrepancy.	Fear & Urgency: Geographic alarmism regarding a login from Moscow.	PHISHING
Sample 2: AI-Generated Request	Name Mismatch (Jose vs. Quinnie), Use of generic @gmail.com for professional inquiry.	Ego-Bait: Highly specific flattery about professional achievement.	SUSPICIOUS
Sample 3: Google Sign-In Alert	Verified accounts.google.com domain, TLS Encryption, transparent official URLs.	Neutral Informing: Provides visibility without demanding immediate action.	SAFE

EMPLOYEE GUIDELINES: DO'S & DON'TS

Based on the risk analysis of Phishing, Suspicious, and Safe email samples, all employees should adhere to the following safety protocols to protect organization and personal data.

Before clicking any link, ask yourself these three questions:

1. Is the sender's actual email address a match? (Check for @gmail.com vs. @microsoft.com).
2. Is there an unusual sense of urgency? (e.g., "Your account will be deleted in 24 hours").
3. Does the link look right? (Hover your mouse over buttons to see the real destination).

CATEGORY	DO	DON'T
Account Alerts	Navigate directly to the official website (e.g., portal.office.com) via your browser instead of clicking the email link.	Click "Report User" or "Verify Now" buttons in emails that use foreign locations to panic you.
External Requests	Verify the sender's identity through a separate channel (Teams, Phone, or WhatsApp) if they claim to be a colleague or professional.	Engage with suspicious emails that flatter your work or research from generic addresses like @gmail or @yahoo.
Suspicious Links	Hover over any link to see the actual URL. Look for subtle misspellings (e.g., micros0ft.com instead of microsoft.com).	Trust a link just because the email mentions your name or a specific project you are working on.
Reporting	Use the built-in "Report Phishing" button in Outlook/Gmail. This alerts the IT Security team immediately.	Forward the phishing email to colleagues to "warn" them; you might accidentally cause them to click the link.